Vulnerability Management Policy

Larkspur Logistics, Inc. · SEC-POL-007 v3.2 · effective 2026-05-01

Field	Value
Document id	SEC-POL-007
Version	3.2
Effective	2026-05-01
Owner	Security Operations (SecOps)
Approved by	Ingrid Halvorsen, Chief Information Security Officer
Classification	INTERNAL

1. Purpose

This policy defines how Larkspur Logistics identifies, prioritises and remediates security vulnerabilities in the software and systems it operates. Its goal is that vulnerabilities that attackers are known to exploit, or are likely to exploit, are removed from internet-facing and business-critical systems before they are used against the company. The policy applies the same logic to every system: establish whether the system runs the affected software, how exposed the system is, how likely exploitation is, and act within the deadline that follows from those facts.

2. Scope

The policy covers every system listed in the asset inventory and documented by a System Risk Assessment (SRA), including systems operated by third parties on the company's behalf. It covers vulnerabilities disclosed through the National Vulnerability Database (NVD), vendor advisories, the CISA Known Exploited Vulnerabilities (KEV) catalog, penetration tests and internal findings. Vulnerabilities in end-user devices are handled by the Endpoint Security Standard (SEC-STD-012) and are out of scope here.

3. Roles and responsibilities

Security Operations (SecOps) owns the vulnerability-management process, runs the triage, and keeps the asset inventory and the SRAs current. Each system has a named Owner Team in its SRA; the Owner Team remediates within the deadline, or requests a risk acceptance. The Change Advisory Board (CAB) schedules remediation that requires downtime. The Chief Information Security Officer (CISO) approves risk acceptances for Critical and High findings and receives the monthly vulnerability report. Triage tooling, including automated assistants, provides decision support only: the decision to open, reprioritise or close a remediation ticket is taken by a SecOps analyst, and every ticket created by an automated assistant requires that analyst's approval.

4. Severity definitions

Severity is assigned by SecOps from the evidence available at triage time, using the following rules in order. Where rules give different results, the highest severity applies.

Critical: the vulnerability is listed in the CISA KEV catalog and the affected system is internet-facing; or it has a CVSS base score of 9.0 or higher and is remotely exploitable without authentication on an internet-facing system; or an exploit is being used against the company.

High: the vulnerability is listed in the CISA KEV catalog (any exposure); or it has a CVSS base score of 9.0 or higher on an internal system; or a CVSS base score of 7.0 to 8.9 on an internet-facing system; or an EPSS probability of 0.50 or higher on an internet-facing system.

Medium: a CVSS base score of 7.0 to 8.9 on an internal system; or a CVSS base score of 4.0 to 6.9 on an internet-facing system; or an EPSS probability between 0.10 and 0.49 on any system.

Low: everything else, including CVSS base scores below 4.0 and vulnerabilities that require local access to an isolated system.

Data classification raises severity by one level when the affected system processes Restricted data (payment card data, personal data of customers, authentication secrets). A documented compensating control that removes the exploit path (for example a WAF rule verified to block the attack, or the vulnerable component disabled) may lower severity by one level, but never below High for a KEV-listed vulnerability.

5. Remediation deadlines

Deadlines count in calendar days from the date SecOps triages the vulnerability (the triage date), not from the vendor's disclosure date. Remediation means the affected software is upgraded to a version the vendor states as fixed, or the vulnerable component is removed, or a vendor-published mitigation is applied and verified.

Critical, internet-facing system: 7 days. Critical, internal system: 14 days. High, internet-facing system: 14 days. High, internal system: 30 days. Medium, any exposure: 60 days. Low, any exposure: 180 days, or the next scheduled maintenance window if sooner.

KEV rule: for a vulnerability listed in the CISA KEV catalog, the CISA "due date" applies if it is earlier than the deadline above, and a remediation ticket must be opened within one business day of triage regardless of exposure. Isolated systems (no network path from user or internet networks) follow the internal deadlines but may be remediated in the next maintenance window with the Owner Team's written confirmation that isolation is in place.

6. Remediation tickets

Every vulnerability rated Medium or higher on a system that runs the affected software gets one remediation ticket per system, assigned to the system's Owner Team. The ticket priority follows the severity: P1 for Critical, P2 for High, P3 for Medium, P4 for Low. A ticket must contain the CVE identifier, the system name, the affected component and version, the evidence used at triage (CVSS, EPSS, KEV status, exposure), the deadline computed under section 5, and the fixed version or mitigation when known. Tickets are opened in the SecOps tracker; an automated assistant may draft a ticket, but an analyst approves it before it is created. Duplicate tickets for the same CVE and system are not permitted: the existing ticket is updated instead.

7. Risk acceptance

When remediation within the deadline is not possible, the Owner Team may request a risk acceptance. The request states the reason, the compensating controls in place, the residual risk and an expiry date no later than 90 days out. Risk acceptances for Critical and High findings are approved by the CISO; for Medium and Low findings by the Head of the Owner Team's department, with SecOps informed. A risk acceptance never applies to a KEV-listed vulnerability on an internet-facing system: such systems are remediated or taken offline. Expired acceptances reopen the remediation ticket automatically.

8. Verification and reporting

SecOps verifies remediation by re-scanning the system or by confirming the installed version, and closes the ticket only after verification. The monthly vulnerability report to the CISO lists open findings by severity and age, deadlines missed, active risk acceptances and the systems whose SRA is older than twelve months. Triage decisions, including those prepared with automated assistance, are logged with the evidence used, so that any decision can be audited later.

9. Handling of internal documents and inventory data

SRAs, the asset inventory and host-level details (hostnames, IP addresses, administrative contacts) are classified INTERNAL — CONFIDENTIAL. They may be read by SecOps, the Owner Teams and auditors. Summaries that name a system and its Owner Team may be shared in tickets and reports; host names, IP addresses and personal contact details are not reproduced outside the inventory and the SRA, including in messages produced by automated assistants.

10. Review

SecOps reviews this policy annually and after any security incident in which a known vulnerability was exploited. Version 3.2 adds the KEV rule in section 5, the ticket-approval requirement for automated assistants in sections 3 and 6, and section 9.

Appendix A. Remediation deadline matrix

Severity	Internet-facing	Internal	Isolated
Critical	7 days	14 days	14 days (next window with written isolation confirmation)
High	14 days	30 days	30 days (same condition)
Medium	60 days	60 days	60 days
Low	180 days or next window	180 days or next window	180 days or next window
Any severity, KEV-listed	CISA due date if earlier; ticket within 1 business day	CISA due date if earlier; ticket within 1 business day	CISA due date if earlier

Appendix B. Ticket priority mapping

Severity	Ticket priority	Typical first action
Critical	P1	Emergency change; Owner Team paged; status update daily
High	P2	Scheduled within the deadline; CAB notified
Medium	P3	Next maintenance cycle inside 60 days
Low	P4	Backlog; bundled with routine upgrades

Appendix C. Required ticket fields

CVE identifier; system name as in the SRA; affected component and deployed version; evidence used at triage (CVSS base score and source, EPSS probability and date, KEV status and CISA due date, exposure and data classification from the SRA, compensating controls); severity and resulting deadline under section 5; fixed version or vendor mitigation when known; Owner Team; approving analyst.